

종합 최종 기술 보고서

하드웨어 제로 트러스트 및 분산 신원인증(DID) 기반의 안전한 익명 모바일 투표 시스템 아키텍처

1. 서론 (Introduction)

본 보고서는 기존 중앙 집중식 모바일 투표 및 여론조사 인프라가 직면한 프라이버시 침해, 이중 당적 가입을 통한 역선택, 리워드 부정 수급(Sybil Attack), 사후 정산 및 무효화의 난해성 등의 취약점을 원천적으로 극복하기 위해 설계된 **HETE-Burde 생태계 기반 제로 트러스트 익명 투표 인프라**의 최종 아키텍처 명세를 기술합니다. 본 시스템은 익명 자격증명(AnonCreds), 영지식 증명(ZKP), 동형암호(Homomorphic Encryption), 하드웨어 수준의 TEE(Trusted Execution Environment) 격리 기술 및 그래프 신경망(GNN) 기반 이상금융 탐지 메커니즘을 융합하여 완전 무결한 분산 장부 거버넌스를 구현합니다.

2. 제로 트러스트 3단계 키 라이프사이클 (3-Tier Key Lifecycle)

유권자의 익명성을 절대적으로 보존하는 동시에 자격 유효성을 상시 검증하기 위해, 키 관리 시스템을 3단계 계층 구조로 모듈화하고 로컬 단말의 하드웨어 보안 영역과 연동합니다.

- **국가 부여 고유 키 (Key 1 - Root Credential):** 주민등록번호, 본적 주소 등 정적 식별 데이터를 기반으로 하되, 정적 유출 및 레인보우 테이블 공격을 방지하기 위해 **AnonCreds의 자격증명 발급(Credential Issuance)** 메커니즘을 적용합니다. 선관위/정부 발급기관(Issuer)이 일회성 솔트(Salt)와 기관 비밀키로 서명한 CL-Signature 형태로 Holder(지갑)에게 제공되므로 원본 정적 데이터는 온체인에 노출되지 않습니다.
- **전자지갑 고유 키 (Key 2 - Device Key Pair):** 단말기 내부 하드웨어 수준의 격리 영역인 **TEE(Trusted Execution Environment, Secure Enclave)**에서 독립적으로 생성되는 비대칭 암호화 키 쌍(Public/Private Key Pair)입니다. 개인키(SK_{device})는 TEE 외부로의 추출이 물리적으로 차단되며 모든 서명 연산은 엔클레이브 내부에서만 직렬화되어 실행됩니다.
- **서비스 키 (Key 3 - Ephemeral Service Key):** 특정 투표 또는 여론조사 세션이 트리거될 때 Key 1(자격증명 토큰)과 Key 2(개인키)의 유기적 조합으로 자동 생성되는 일회성 비밀키입니다. 이 서비스 키의 정당성은 외부 유출 없이 **영지식 증명(Zero-Knowledge Proof)** 메커니즘을 통해 투표 검증 시스템에 전달되므로 역추적이 원천 차단됩니다.

3. 하드웨어 TEE 분할 대여 기반 사회적 복구 (Social Recovery)

선거 당일 단말기 분실, 파손 등 비상 상황 발생 시 키 갱신(Key Rotation)으로 인한 투표 관리 장부의 동시성 교란을 방지하기 위해, 신뢰 네트워크를 통한 로컬 사회적 복구 프로토콜을 정립합니다.

TEE 분할 및 격리 바인딩 규칙

유권자는 사전에 행정망(가족관계증명서 VP)을 통해 익명 인증된 직계가족 또는 신뢰 지인의 단말기 TEE 영역의 일부를 분할 대여받아 백업 체인(최대 3개 제한)을 형성합니다. 백업 호스트 단말기는 저장 공간만 물리적으로 내어줄 뿐이며, 원 소유주의 생체 인증(PIN/Bio-Attestation) 없이는 하드웨어 수준에서 격리되므로 가족이라 할지라도 원본 **Key 2**를 탈취할 수 없습니다. 분실 발생 시 오프라인 대면 기관을 방문하지 않고도 근거리 보안 채널을 통해 원본 **Key 2**를 실시간 복구하여 기존 임시 토큰으로 정당하게 투표권을 행사할 수 있습니다.

4. MNP 프로토콜 적용 정당 이동성 & 계층적 멀티 인증 체계

한국 정치권의 고질적 취약점인 배타적 정당의 이중 가입 및 역선택 부정을 차단하기 위해 이동통신사의 번호이동(Mobile Number Portability, MNP) 원리를 분산 장부에 도입합니다.

가입 및 탈퇴 프로세스는 단일 원자적 트랜잭션(Atomic Transaction)으로 묶여 집행됩니다. 유권자가 A정당 가입을 신청함과 동시에 기존 B정당 가입 증명서(ZKP)를 정부 1차 인증 서버에 제출하면, 개통 시점을 기준으로 블록체인 네트워크 상에서 B정당의 당원 자격증명은 즉시 만료(Revoked)되고 A정당 자격 원장이 업데이트됩니다. 이는 정부의 1차 신원 인증과 각 정당 및 이동사의 2차 권한 검증이 완전 분리된 **계층적 제로 트러스트 아키텍처(ZTA)** 모델로 기능하며, 개인 지갑 내부에서 상태 데이터(State)를 상시 Keeping 관리하도록 강제함으로써 동시성 충돌을 차단합니다.

5. 복식 부기 기반 이원화 장부 및 동형암호 집계 메커니즘

내부자 위협 및 유령 투표 끼워넣기를 원천 차단하기 위해 투표 인명부 관리 시스템(장부 A)과 투표 집계 시스템(장부 B)을 독립 분리하고 현대 회계의 복식 부기 원리를 매핑합니다.

$$\sum [\text{차변: Voter Manager 발급 투표 권한(Token) 수}] = \sum [\text{대변: Tally Accumulator 정상 접수 암호문 수}]$$

최종 정산(Reconciliation) 마감 시 두 이원화 장부의 총계는 소수점 단위까지 정확히 일치해야 마감이 승인됩니다. 유권자가 행사한 표값은 지갑단에서 **동형암호(Homomorphic Encryption)**로 감싸져 인구통계학적 속성(연령대, 성별) 암호문 패킷과 결합(Binding)됩니다. 집계기관은 표를 복호화하지 않고 암호화된 상태 그대로 누적 합산(homomorphicAdd) 연산을 집행하며, 마감 시점에 바스켓 전체를 일괄 복호화하여 "누가 투표했는지는 우주 전체에서 아무도 알 수 없으나, 특정 연령대 및 정당 지지율 분포"는 100% 신뢰도로 자동 산출되는 제로-응답(Zero-Response) 통계 장부를 정산해 냅니다.

6. AI 에이전트 위임 프로토콜 및 명시적 텍스트 토큰 스키마

온디바이스 SLM(소형 거대언어모델)이 대중화되기 전 과도기 단계에서, 빈번한 여론조사와 당내 투표의 응답률을 극대화하고 처리 비용을 낮추기 위해 AI 에이전트 자동 위임 프로토콜을 규정합니다.

유권자는 지갑 내 사전 설정(Pre-voting Settings) 레이어에 자신의 지지 성향을 마킹해 둡니다. 여론조사 기관이 송신하는 데이터 패킷에는 정형화된 **명시적 텍스트 토큰 스키마**가 강제됩니다. AI 에이전트는 유권자의 마스터 개인키(Key 2)를 직접 건드리지 않고, TEE 내부에서 스코프가 지정되어 발급된 임시 프록시 위임 토큰(Delegation Token)을 사용하여 규격 매칭 시 자율 투표를 트리거합니다. 투표 결과는 **영외(Out-of-Band) 푸시 알림 및 유권자 개인키로만 열리는 암호화 QR/이미지 영수증** 형태로 강제 송신되어 인간이 최종 통제권을 유지(User-in-the-Loop)하도록 설계합니다.

7. GNN 사기 탐지(VDS) 및 집합적 사기 증명 수학적 명제

이권이 걸린 선거에서 발생 가능한 대규모 봇넷 및 에뮬레이터 기반 리워드 사냥 행위를 실시간 탐지하기 위해 금융권 수준의 GNN 이상거래 탐지 레이어(VDS)를 가동합니다. 탐지는 HETE-Burde의 메모리 그래프 엔진 및 TigerGraph 보조 체인을 기반으로 실시간 스트리밍 연산(pyGOD 모델 융합)을 수행합니다.

[명제 1] 널리파이어 생성 함수 일치 법칙 (Coordinated Nullifier Generation)

공격자가 동일 단말에서 자격증명을 무작위 교체하며 매크로 공격을 실행할 시, 쌍선형 가환 군($e: G_1 \times G_2 \rightarrow G_T$) 상에서 단말 고유 키와 조사 ID의 매핑 관계에 공통 인자가 노출됨을 증명합니다.

$$\forall n_p, n_j \in N_{\text{fraud}} (i \neq j) : e(n_p, g_2) = e(H(ID_{\text{survey}}), PK_{\text{device}}) \cdot e(A_p, g_2)$$

[명제 2] 그래프 토폴로지 엔트로피 임계치 법칙 (Topological Entropy Threshold)

정상 가족 백업망과 달리 봇넷 집단은 소수의 브로커 노드로 백업 체인이 집중되므로, 샤논 엔트로피($H(G)$)의 조밀도가 설정된 하한 임계치 미만으로 수렴함을 영지식 증명 회로문 내에서 검증합니다.

$$H(G) = - \sum P(d) \log_2 P(d) \rightarrow \Pi_{Topology} \equiv ZK-PoK \{ H(G_{fraud}) < \theta_{lower} \mid G_{fraud} \subset G_{Total} \}$$

8. mTLS 보안 릴레이어 & 사법 기관 자동 이첩 gRPC 명세

VDS 시스템에 의해 **Status::Suspended** 등급으로 실시간 격리된 조직적 사기 봇넷 데이터셋은 하이브리드 암호화 봉인(ECIES + AES-256-GCM)을 거쳐 사법 기관(경찰청·법원 형사사법정보시스템: KICS)으로 유실 없이 실시간 Push 전송됩니다. 통신로는 X.509 v3 기반의 양방향 **mTLS 터널(TLS 1.3)**로 보호됩니다.

```
syntax = "proto3";
package hete.judicial.v1;

service JudicialWarrantService {
  rpc PushFraudEvidencePipeline (stream PushFraudEvidenceRequest) returns
    (PushFraudEvidenceResponse);
}

message PushFraudEvidenceRequest {
  string idempotency_key = 1;          // 중복 수신 방지용 멍등성 해시 키
  uint64 cosmos_trigger_height = 2;   // 온체인 이벤트 블록 고도
  string survey_id = 3;               // 여론조사 고유 식별자
  bytes encrypted_evidence_payload = 4; // 법원 공개키($PK_{Judicial}$)로 봉인된 VP 페이로드
  bytes transient_aes_key_cipher = 5;  // ECIES로 암호화된 AES 대칭키
  string cryptographic_tsa_token = 6;   // 시점확인기관(TSA) 인증 토큰
}

message PushFraudEvidenceResponse {
  string idempotency_key = 1;
  enum PipelineStatus {
    UNSPECIFIED = 0;
    QUEUED = 1;          // 사법 내부 접수 큐 안착 완료
    DUPLICATE = 2;       // 중복 인입 제어
    VERIFICATION_FAILED = 3; // 증명 무결성 검증 실패
  }
  PipelineStatus status = 2;
  uint64 kics_receipt_number = 3;
  int64 timestamp_ms = 4;
}
```

9. CosmWasm 사법 영장 콜백(Callback) 및 몰수 정산 핸들러

사법 기관의 심사를 거쳐 발부된 전자영장 증명서(**WarrantIssuedVP**)가 온체인에 인입되면, CosmWasm Rust 컨트랙트는 차-대변 장부를 동시에 영구 삭감하고 리워드를 국고로 강제 환수합니다.

```

pub fn handle_judicial_verify_reply(deps: DepsMut, env: Env, msg: Reply) -> Result {
    let reply_data = parse_reply_execute_data(msg)?;
    let verification_result: VerificationResult = from_json_binary(&reply_data.data.unwrap())?;
    let nullifier_root = verification_result.nullifier_root;
    let warrant = PENDING_LEGAL_SETTLEMENT.load(deps.storage, &nullifier_root)?;

    if verification_result.is_approved {
        // 1. 장부 A (Voter Manager): 사기 지갑 상태를 영구 블랙리스트로 확정 전이
        update_nullifiers_status(deps.storage, &nullifier_root, Status::PermanentBlacklist)?;

        // 2. 장부 B (Tally Accumulator): 동형합산 대기 큐에서 사기 암호문 원천 퍼지(Purge) 메시지 전송
        let tally_void_msg = WasmMsg::Execute {
            contract_addr: warrant.tally_contract_addr.clone(),
            msg: to_json_binary(&TallyExecuteMsg::PurgeSuspendedVotes { nullifier_root })?,
            funds: vec![],
        };

        // 3. 리워드 장부 (Reward Escrow): 락업된 리워드를 차감하여 국고(Treasury) 계좌로 강제 बैंक 송금
        let escrow_forfeit_msg = WasmMsg::Execute {
            contract_addr: warrant.escrow_contract_addr.clone(),
            msg: to_json_binary(&EscrowExecuteMsg::ForfeitToTreasury {
                nullifier_root,
                treasury_address: "cosmos1treasury_national_public_vault...".to_string()
            })?,
            funds: vec![],
        };

        Ok(Response::new()
            .add_messages(vec![tally_void_msg, escrow_forfeit_msg])
            .add_attribute("settlement_status", "permanent_legal_forfeiture_committed"))
    } else {
        // [각각 시 안전 롤백] 상태 복구 및 에스스로 락 해제
        update_nullifiers_status(deps.storage, &nullifier_root, Status::Active)?;
        let rollback_msgs = build_rollback_messages(deps.as_ref(), &warrant)?;
        Ok(Response::new().add_messages(rollback_msgs))
    }
}

```

10. 특허 청구 범위 정교화 (Refined Patent Claims)

[청구항 1] (독립항: 하드웨어 격리 및 계층적 익명 신원 유도 기반 모달 투표 인프라)

유권자 단말기 및 블록체인 네트워크와 연동되어 신원 보호형 투표를 처리하는 시스템에 있어서,

상기 유권자 단말기의 하드웨어 보안 영역(TEE) 내부에서 격리 생성된 비대칭 키 쌍의 개인키(SK_{device}) 및 공개키(PK_{device})를 정립하는 단계;

정부 발급기관 서버가 상기 유권자의 정적 신원 식별정보에 일회성 암호 솔트와 기관 서명을 결합하여 익명 자격증명(AnonCreds Credential 토큰)을 발급하고 상기 단말기에 보관시키는 단계;

선거 세션 트리거 시 상기 TEE 엔클레이브가 상기 발급된 자격증명 토큰과 상기 기기 개인키(SK_{device})를 암호학적으로 결합하여 세션 일회성 서비스 키를 유도하는 단계;

상기 유권자 단말기가 상기 서비스 키의 원본 데이터를 외부 노출하지 않고 영지식 증명(Zero-Knowledge Proof) 회로문을 통해 산출된 자격 증명만을 투표관리 서버로 전송하는 단계;

를 포함하는 제로 트러스트 하드웨어 격리 기반 익명 모바일 투표 방법.

[청구항 2] (종속항: MNP 메커니즘을 적용한 원자적 당적 이동 및 계층적 상태 지갑)

제1항에 있어서,

상기 유권자 단말기가 신규 정당 가입 요청 메시지와 함께 기존 소속 정당의 가입 상태 증명 영지식 패킷을 통합 인증 허브 서버로 전송하는 단계;

상기 통합 인증 허브 서버가 상기 유권자의 실제 신원을 익명화한 상태에서 신규 정당의 원장 개통 승인 시점과 기존 정당의 당원 자격 폐기(Revocation) 시점을 단일 블록체인 트랜잭션 내에서 동기화하여 처리하는 단계;

상기 단말기 내부 지갑 애플리케이션이 상기 계층적 멀티 인증 상태 변수(State)를 로컬 TEE 영역 내에 Keeping 저장하여 장부 간 레이스 조건을 차단하는 단계;

를 포함하는 원자적 소속 이동 방법.

[청구항 3] (종속항: 복식 부기 이원화 원장 및 동형합산 정산 규칙)

제1항에 있어서,

유권자 권한과 일회성 무효화 식별자(Nullifier)를 매핑 기록하는 투표 관리 계약(장부 A)과, 동형암호화된 표값만을 적재하는 집계 계약(장부 B)을 독립 분리 구동하는 단계;

상기 장부 A의 유동 자격 카운트 총량(차변)과 상기 장부 B의 암호문 접수 총량(대변)이 마감 시점에 교차 대조되어 오차율 0.00%를 만족할 때에 한해 청산(Settlement)을 승인하는 단계;

를 포함하는 복식 부기 기반 투표 정산 방법.

[청구항 4] (종속항: GNN 사기 탐지 연계 및 사법 영장 기반 온체인 자동 몰수 프로토콜)

제3항에 있어서,

서버단 스트리밍 GNN 알고리즘이 유권자 지갑 간의 관계 토폴로지의 엔트로피 및 잠재 공간 내 응집도를 스코어링하여 사기 봇넷으로 판정된 널리파이어 집합을 실시간 추출하는 단계;

상기 장부 A가 상기 판정된 널리파이어 상태를 임시 유예($Status::Suspended$)로 변경하여 장부 B의 집계 바스켓 연산에서 격리하는 단계;

보안 릴레이어가 상기 사기 증명 VP를 사법 루트 공개키로 하이브리드 봉인하여 mTLS 통널을 통해 형사사법정보망(KICS) 큐에 push 이첩하는 단계;

법원이 발부한 전자영장 서명이 콜백 접수되면, CosmWasm 스마트 컨트랙트 핸들러가 상기 널리파이어 상태를 영구 박탈($Status::PermanentBlacklist$)로 확정 전이하고, 에스크로 계약 내에 묶여 있던 보상 자산을 차감하여 지정 국고 계좌로 원자적 포워딩(Forfeiture)하는 단계;

를 포함하는 사기 투표 실시간 무효화 및 사법 자산 몰수 방법.